

Controls and Compliance Checklist

Controls assessment checklist

Yes	No	Control
☐	☒	Least Privilege
☐	☒	Disaster recovery plans
☐	☒	Password policies
☐	☒	Separation of duties
☒	☐	Firewall
☐	☒	Intrusion detection system (IDS)
☐	☒	Backups
☒	☐	Antivirus software
☒	☐	Manual monitoring, maintenance, and intervention for legacy systems
☐	☒	Encryption
☐	☒	Password management system
☒	☐	Locks (offices, storefront, warehouse)
☒	☐	Closed-circuit television (CCTV) surveillance
☒	☐	Fire detection/prevention (fire alarm, sprinkler system, etc.)

Compliance Checklist

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice
☐	☒	Only authorized users have access to customers' credit card information.
☐	☒	Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment.
☐	☒	Implement data encryption procedures to better secure credit card transaction touchpoints and data.
☐	☒	Adopt secure password management policies.

Reason: Botium Toys does not have proper access controls, encryption, or strong password management in place to fully protect cardholder data

General Data Protection Regulation (GDPR)

Yes	No	Best practice
☐	☒	E.U. customers' data is kept private/secured.
☒	☐	There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.
☐	☒	Ensure data is properly classified and inventoried.
☒	☐	Enforce privacy policies, procedures, and processes to properly document and maintain data.

Reason: Botium Toys has privacy procedures and a breach notification plan, but customer data protection and asset classification need improvement.

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	No	Best practice
☐	☒	User access policies are established.

- | | | |
|-------------------------------------|-------------------------------------|--|
| ☐ | ☒ | Sensitive data (PII/SPII) is confidential/private. |
| ☒ | ☐ | Data integrity ensures the data is consistent, complete, accurate, and has been validated. |
| ☒ | ☐ | Data is available to individuals authorized to access it. |

Reason: Botium Toys has controls supporting data integrity and availability, but access management and data confidentiality need improvement.

Recommendations for the IT Manager

Based on the audit results, I recommend that Botium Toys:

- Implement stronger access controls to ensure employees only access information required for their job duties.
- Encrypt customer payment information to protect sensitive financial data.
- Improve password security by enforcing stronger password requirements and using centralized password management.
- Create a complete asset inventory and classify company data based on sensitivity and importance.
- Implement additional monitoring tools, such as an Intrusion Detection System (IDS).
- Create regular backups and develop a disaster recovery plan.
- Continue maintaining existing security controls, including firewall protection, antivirus software, physical security, and privacy procedures.